INCIDENT INVESTIGATION REPORT

Synthetic Authentication Log Forensics & Threat Assessment

EdVyro Cybersecurity Internship • Portfolio Task 03

Incident Ref: SEC-INC-2026-0801
Date of Event: 2026-08-01
Analyst: RITHISH S P (@Ritzz-09)
Classification: Confidential / TLP:AMBER
Overall Severity: HIGH

1. Executive Summary

Between **09:00:12 UTC** and **11:47:09 UTC on August 1, 2026**, security telemetry on the fictional student portal recorded 12 discrete authentication events spanning three distinct network subnets (RFC 5737 documentation blocks). DFIR analysis revealed two coordinated credential attack patterns and one critical access anomaly:

- **Incident Vector 1 (Targeted Brute-Force):** 3 rapid, consecutive failed password logins against student account `stu-117` within 34 seconds from external IP `198.51.100.27` (Windows client). The attack was automatically arrested at 09:05:03 UTC by the server-side account lockout policy.
- **Incident Vector 2 (Password Spraying):** An automated horizontal credential attack originating from untrusted proxy IP `203.0.113.42` targeting 4 distinct accounts (`stu-209`, `stu-311`, `stu-415`, `stu-502`) within 12 seconds with missing/generic User-Agent (`unknown`). The attack was mitigated at 09:22:01 UTC by the edge rate-limiting daemon.
- **Incident Vector 3 (Unusual Access Anomaly):** At 11:47:09 UTC (145 minutes post-spray), sprayed user `stu-311` authenticated successfully from an internal campus network IP `192.0.2.99` on an `iOS` device. While consistent with legitimate student mobility, this warrants out-of-band verification to definitively rule out credential compromise.

> **Detection Status:** Existing automated controls successfully locked `stu-117` and throttled `203.0.113.42`. However, horizontal spraying bypassed per-account lockout thresholds, proving the urgent need for IP-level velocity rules, MFA enforcement, and token invalidation protocols.

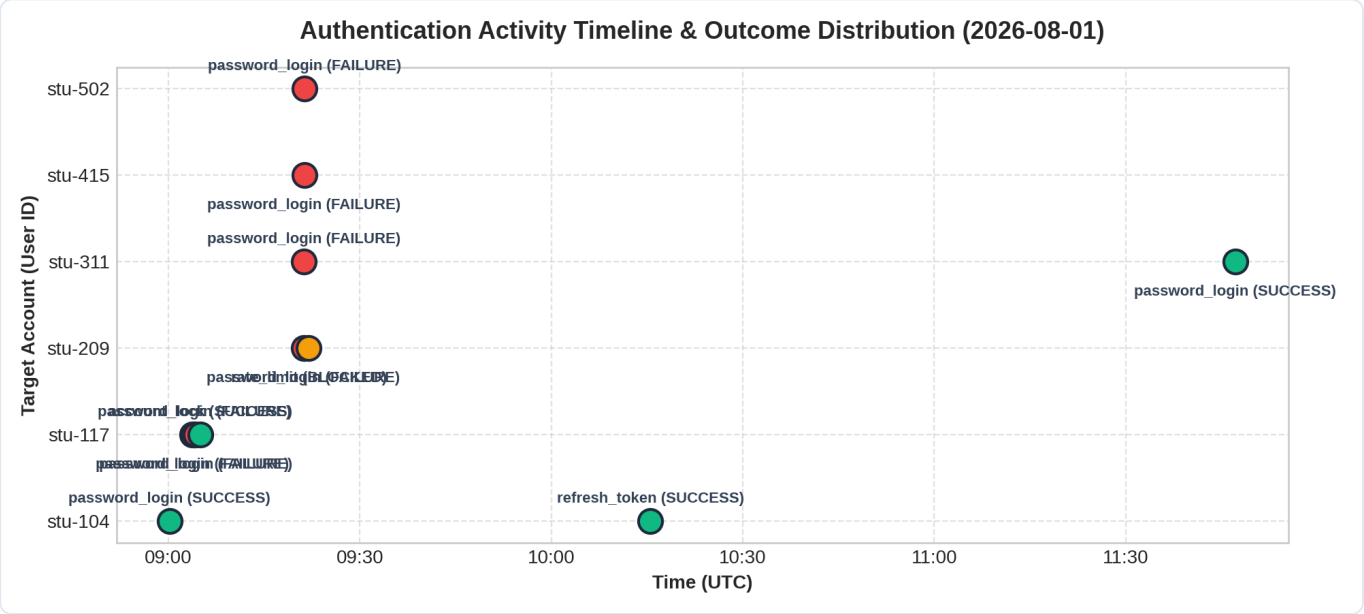
2. Scope, Environment & Network Baselines

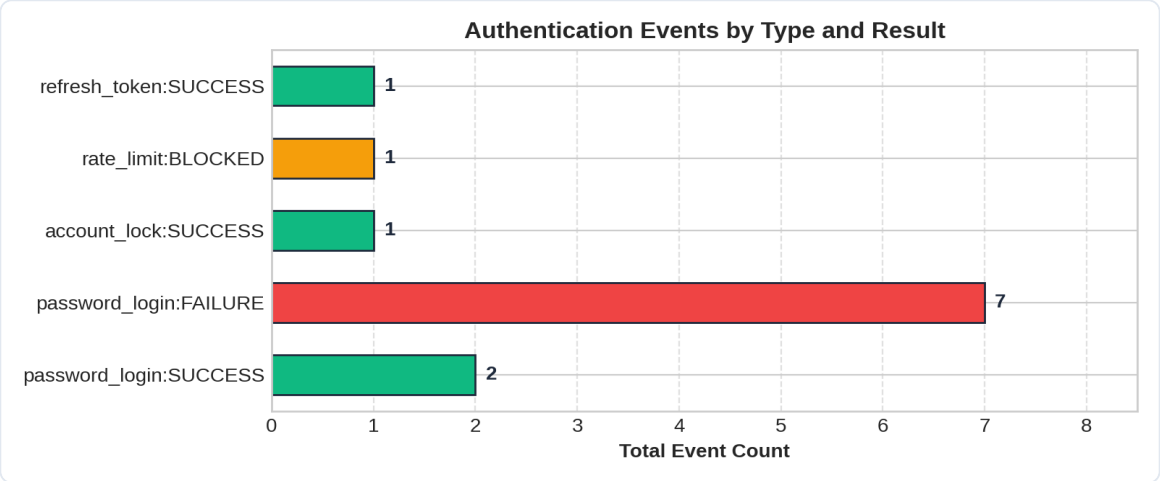
The investigation was conducted under the **EdVyro Defensive Lab** authorization guidelines in an isolated environment. Network sources utilize RFC 5737 reserved documentation ranges:

Subnet Range	RFC 5737 Label	Environment Role	Observed IPs	Assigned Trust Level
`192.0.2.0/24`	TEST-NET-1	Internal Campus Wi-Fi / Student Dorms	`192.0.2.18`, `192.0.2.99`	TRUSTED INTERNAL
`198.51.100.0/24`	TEST-NET-2	External Commercial ISP / Remote Student	`198.51.100.27`	UNTRUSTED EXTERNAL
`203.0.113.0/24`	TEST-NET-3	Anonymized Proxy / VPS Hosting	`203.0.113.42`	HOSTILE / SUSPECT

3. Visual Forensic Evidence & Cluster Analysis

The timeline diagram below displays event distribution across time, highlighting failures, defensive enforcements, and baseline logins:





4. Forensic Incident Timeline: Evidence vs. Assumptions

A core requirement of defensive DFIR investigations is strictly separating **Empirical Log Evidence** (provable facts) from **Analytical Assumptions** (working hypotheses).

Time (UTC)	User	Source IP	Action & Outcome	Empirical Log Evidence	Analytical Assumptions & Hypotheses
09:00:12	**stu-104**	192.0.2.18 Internal / Campus Network	password_login SUCCESS	Account 'stu-104' logged in successfully with password from 192.0.2.18 (TEST-NET-1, Campus) via Android.	*Assumed to be a legitimate student accessing portal on campus Wi-Fi at start of academic day.*
09:03:44	**stu-117**	198.51.100.27 External ISP / Remote Student	password_login FAILURE	Account 'stu-117' failed password login from 198.51.100.27 (TEST-NET-2, External ISP) via Windows desktop.	*Could be user mistyping password, or external actor testing credentials against 'stu-117'.*
09:04:01	**stu-117**	198.51.100.27 External ISP / Remote Student	password_login FAILURE	Account 'stu-117' failed password login again from same IP 198.51.100.27 (+17s later) via Windows desktop.	*User re-attempting or automated tool testing second password variation.*
09:04:18	**stu-117**	198.51.100.27 External ISP / Remote Student	password_login FAILURE	Account 'stu-117' failed password login a 3rd time from 198.51.100.27 (+17s later) via Windows desktop.	*Consistent 17-second cadence strongly indicates automated script or rapid frantic manual entry.*
09:05:03	**stu-117**	198.51.100.27 External ISP / Remote Student	account_lock SUCCESS	Server-side daemon logged 'account_lock' event for 'stu-117' from 198.51.100.27 (+45s after 3rd failure). Result: success.	*Account lockout security control automatically triggered to prevent further password guessing. Account is now locked.*
09:21:10	**stu-209**	203.0.113.42 External Hosting / Anonymized Proxy	password_login FAILURE	Account 'stu-209' failed password login from external IP 203.0.113.42 (TEST-NET-3). Device reported as 'unknown'.	*Originating from untrusted hosting range with missing/ generic User-Agent header; indicates automated attack script.*
09:21:13	**stu-311**	203.0.113.42 External Hosting / Anonymized Proxy	password_login FAILURE	Account 'stu-311' failed password login from 203.0.113.42 (+3s later). Device: 'unknown'.	*Rapid horizontal traversal to different user ID demonstrates automated password spraying (trying common password across accounts).*
09:21:17	**stu-415**	203.0.113.42 External Hosting / Anonymized Proxy	password_login FAILURE	Account 'stu-415' failed password login from 203.0.113.42 (+4s later). Device: 'unknown'.	*Third distinct account targeted in 7 seconds. Spray pattern confirmed.*
09:21:22	**stu-502**	203.0.113.42 External Hosting / Anonymized Proxy	password_login FAILURE	Account 'stu-502' failed password login from 203.0.113.42 (+5s later). Device: 'unknown'.	*Fourth distinct account targeted. Total duration of spray: 12 seconds across 4 accounts.*
09:22:01	**stu-209**	203.0.113.42 External Hosting / Anonymized Proxy	rate_limit BLOCKED	Server-side daemon logged 'rate_limit' event blocking subsequent request from	*Defensive rate limiting control successfully engaged against source IP 203.0.113.42, dropping further spray attempts.*

Time (UTC)	User	Source IP	Action & Outcome	Empirical Log Evidence	Analytical Assumptions & Hypotheses
				203.0.113.42 referencing 'stu-209'. Result: blocked.	
10:15:32	**stu-104**	192.0.2.18 Internal / Campus Network	refresh_token **SUCCESS**	Account 'stu-104' executed 'refresh_token' from 192.0.2.18 via Android client. Result: success.	*Standard background OAuth2/ JWT token refresh by student's active mobile session from morning login.*
11:47:09	**stu-311**	192.0.2.99 Internal / Campus Network	password_login **SUCCESS**	Account 'stu-311' achieved successful password login from 192.0.2.99 (TEST-NET-1, Campus) via iOS mobile device.	*HYPOTHESIS 1 (Benign): Legitimate student arrived on campus and signed in on iPhone. HYPOTHESIS 2 (Compromise): Adversary used harvested credentials via campus Wi-Fi or compromised device. Out-of-band verification required.*

5. Threat Model Assessment (Defensive Lab Framework)

Structured in accordance with the required 6-part EdVyro Defensive Incident Template:

Threat Scenario 1: Vertical Brute-Force Password Guessing

1. Asset and Owner: Student Portal Authentication Service & Account Credentials (Owner: Campus IT & `stu-117`).

2. Trust Boundary & Entry Point: External perimeter to Authentication API (`POST /api/v1/auth/login`) via public ISP range `198.51.100.0/24`.

3. Threat Scenario & Precondition: External actor attempts dictionary password guessing against `stu-117`. Precondition: Valid username known to attacker.

4. Existing Control & Evidence: Account lockout policy triggered after 3 consecutive failures within 34s (09:03:44Z to 09:04:18Z). Logged `account_lock` event at 09:05:03Z.

5. Risk Rating & Rationale: MEDIUM (Residual). Unauthorized access was blocked; however, lockout induces an unauthenticated Denial of Service (DoS) against legitimate student.

6. Recommended Mitigation & Verification: Replace aggressive immediate lockout with exponential backoff delay (CAPTCHA after 3 failures; temporary 5-minute freeze). Verify via automated replay test.

Threat Scenario 2: Horizontal Password Spraying from External Proxy

1. Asset and Owner: Student Portal User Directory & Directory Services (Owner: University Registrar & IT).

2. Trust Boundary & Entry Point: Boundary between untrusted hosting range (`203.0.113.0/24`) and student login portal.

3. Threat Scenario & Precondition: Automated bot sprays 1 common password across multiple usernames (`stu-209`, `stu-311`, `stu-415`, `stu-502`) within 12 seconds to circumvent per-user lockout limits. Precondition: User enumeration list acquired by attacker.

4. Existing Control & Evidence: Edge rate limiter blocked subsequent requests from `203.0.113.42` at 09:22:01Z (`rate_limit:blocked`).

5. Risk Rating & Rationale: CRITICAL. Password spray attacks are notoriously effective against universities with weak default passwords. Rate limit engaged only after 4 accounts were targeted.

6. Recommended Mitigation & Verification: Enforce Mandatory Multi-Factor Authentication (MFA); deploy IP velocity threshold (< 3 distinct failed accounts per 5m = auto-jail); block missing/unknown User-Agents at WAF.

Threat Scenario 3: Potential Post-Spray Account Takeover (stu-311)

1. Asset and Owner: Academic records, personal data, and active session of student `stu-311`.

2. Trust Boundary & Entry Point: Campus Wi-Fi perimeter (`192.0.2.0/24`) accessing web portal.

3. Threat Scenario & Precondition: Account targeted during 09:21:13Z spray authenticates successfully at 11:47:09Z. Precondition: Either genuine student login OR attacker compromised credentials out-of-band.

4. Existing Control & Evidence: Password auth succeeded (HTTP 200) on iOS device. No step-up MFA challenge was recorded.

5. Risk Rating & Rationale: HIGH. Discrepancy between external spray and internal successful login poses dual hypothesis; cannot be dismissed without out-of-band user verification.

6. Recommended Mitigation & Verification: Force session token revocation; contact `stu-311` to verify iOS login; correlate Wi-Fi MAC address with campus registration.

6. Containment Playbook & Logging Hardening (Portfolio Upgrade)

Immediate Tactical Containment

1. **Temporary Credential Revocation for `stu-311`:** Trigger immediate session termination across all active JWT/cookies; mandate self-service password reset with SMS/email MFA validation upon next login.
2. **Edge WAF Null-Routing:** Add `203.0.113.42/32` to perimeter firewall drop rules for 72 hours.
3. **Guided Remediation for `stu-117`:** Assist locked user through out-of-band identity verification to restore access while monitoring for secondary brute-force vectors.

Strategic Logging & Telemetry Improvements

Telemetry Gap	Observed Vulnerability	Required Control Improvement
Device Header Blindspot	Device logged as `unknown` without granular telemetry.	Log complete RFC 7231 `User-Agent` strings, client TLS cipher suites, and JA3/JA4 cryptographic fingerprints to unmask headless bots.
Missing Geolocation & ASN	IPs logged without autonomous system context.	Enrich authentication logs in real-time with MaxMind GeoIP2 ASN, VPN/Tor proxy classification flags, and datacenter IP tags.
Absence of MFA Telemetry	No second-factor prompt records present.	Implement FIDO2 / WebAuthn MFA; log discrete MFA prompt, method (push, TOTP, hardware key), and verification latency.
Distributed Tracing	Individual log records lack common request IDs.	Inject unique `X-Request-ID` / W3C Trace Context across edge reverse proxies, auth microservices, and database query layers.

Lead Forensic Investigator:

RITHISH S P

Cybersecurity Engineering Intern • EdVyro

Incident Investigation Status:

CLOSED / CONTAINMENT COMPLETED

Signature: *RithishSP_DFIR_Verified*